LABORATUVAR 5 — AKEMSAN AE.HAOD.3C Tomruk Arabası

SBOM / CVE / Patch

Çıktı: Vulnerability Decision | Tarih: 31.10.2026

Ad Soyad: Yiğit Kerem Canbay | Öğrenci No: 235541046 | Şube: Gece | Tarih: 31.10.2026

Kavram: SBOM = yazılım malzeme listesi • CVE = açığın kayıt no'su • CVSS = ciddiyet (0-10). Bir CVE sizi etkiler mi? Üç şart: bileşen var, sürüm etkileniyor, açık ulaşılabilir.

Verilen zafiyet kaydı

Bileşen	Akemsan Tomruk Arabası PLC firmware kütüphanesi (Haberleşme modülü)
Sürüm	2.4
CVE	CVE-2026-4892
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Evet, etkiliyor. Üç şartı sağladığı görülmüştür: 1) Akemsan AE.HAOD.3C sisteminde ilgili PLC haberleşme kütüphanesi bileşeni aktif olarak kullanılmaktadır. 2) Sistemdeki sürüm 2.4 zafiyetten doğrudan etkilenmektedir. 3) Uzaktan bakım (teleservis) arayüzü üzerinden bu zafiyete dışarıdan ağ üzerinden ulaşılabilmektedir.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Üretimi hemen durdurmayız. Nedeni: Panik ile üretimi durdurmak yüksek maliyet ve operasyonel aksama yaratır. Zafiyet kritik (CVSS 9.8) olmasına rağmen henüz aktif bir sömürü (exploit) kanıtı yoktur. Risk değerlendirmesi yapılarak planlı bakım penceresinde müdahale edilir veya geçici telafi edici önlemler devreye alınır.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Yamayı asla doğrudan canlı sisteme uygulamayız. Önce üreticinin test tezgâhında / izole laboratuvar ortamında (veya dijital ikizde) doğrulaması yapılır. Kararlılık ve emniyet testleri başarıyla geçildikten sonra planlı duruş anında sisteme uygulanır.

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Evet, etkileyebilir. PLC haberleşme yığınındaki bir güncelleme, Safety PLC ile haberleşme protokolünü veya emniyet imzasını dolaylı yoldan etkileyebilir. Bunu anlamak için yama sonrası sistem üzerinde yeni bir fonksiyonel güvenlik doğrulama (Safety Validation) ve entegrasyon testi koşturulur.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Yama uygulanamıyorsa; savunmada derinlik ilkesi gereği ilgili zafiyetli port veya servis güvenlik duvarı (Firewall) kurallarıyla dış dünyaya kapatılır, ağ segmentasyonu sıkılaştırılır, teleservis erişimi geçici olarak askıya alınır veya manuel gözetimli işletim prosedürlerine geçilir.

Bu föyün çıktısı Vulnerability Decision -> Evidence Pack EP 09 - 10 - 11 başlığına oturur.